

GZ: 2023-0.592.319 dated January 4, 2024 (Case Number: DSB-D550.515)

[Note from the editor: Names and companies, legal forms and product names, addresses (including URLs, IP and email addresses), file numbers (and the like), etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected.]

****Criminal Finding****

Accused legal entity: N*** - Football Association (ZVR: *6*7**88*)

The accused legal entity with its registered office in **** T***dorf, J***straße *7 (hereinafter: the Accused), has, as the responsible party in the sense of Art. 4 Z 7 of Regulation (EU) 2016/679 on the protection of natural persons in the processing of personal data, on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter: "GDPR"), OJ No. L 119 of May 4, 2016, p. 1 as amended, committed the following administrative offenses:

I. The Accused has, as the responsible party, violated its obligation under Art. 25 para. 1 GDPR during a period that cannot be precisely determined, but in any case from May 25, 2018, to date ("Offense Period 1"), within the territory of Austria ("Crime Scene"), by failing to take appropriate technical and organizational measures so that in the event of a required deletion—whether at the request of a data subject or on its own initiative—personal data of players who have participated in at least one game in the league organized by the Accused are completely deleted from the publicly accessible database on the website https://www.n***.com/.

II. Furthermore, the Accused has, as the responsible party, violated Art. 17 GDPR during the period from September 23, 2020, to date ("Offense Period 2"), within the territory of Austria ("Crime Scene"), by not fully complying with the deletion request of Mr. Roberto B*** dated September 23, 2020. The affected person had the right under Art. 17 para. 1 GDPR to have his data deleted, and the Accused was obliged to delete the personal data of the affected person without delay. None of the exceptions under Art. 17 para. 3 GDPR were applicable in this specific case. The Accused continues to process personal data of Mr. Roberto B*** by publishing his personal data under the URL https://www.n***.com/?action=showPlayer&id;=*4*6 on its website.

III. Finally, the Accused has, during the period from May 11, 2021, to date ("Offense Period 3"), within the territory of Austria ("Crime Scene"), failed to comply with the performance order in item 2.b. of the legally binding decision of the Data Protection Authority dated May 10, 2021, GZ: D124.3076, 2021-0.096.835, which was demonstrably delivered to it on May 11, 2021, by not deleting the personal data of the affected person or storing it in a non-publicly accessible area. Thus, the Accused has not complied with an instruction from a supervisory authority in the sense of Art. 58 para. 2 lit. c GDPR.

****Administrative Offenses according to:****

Ad I.: Art. 25 para. 1 in conjunction with Art. 83 para. 1 and 4 lit. a GDPR OJ L 2016/119, p. 1, as amended

Ad II.: Art. 17 para. 1 in conjunction with Art. 83 para. 1 and 5 lit. b GDPR OJ L 2016/119, p. 1, as amended

Ad III.: Art. 58 para. 2 lit. c in conjunction with Art. 83 para. 1 and 6 GDPR OJ L 2016/119, p. 1, as amended

Due to these administrative offenses, the following penalty is imposed in accordance with Art. 83 GDPR:

Fine of Euro

€ 11,000,-

according to

Art. 83 para. 4 lit. a, para. 5 lit. a and para. 6

GDPR

Furthermore, you are to pay according to § 64 of the Administrative Penal Act 1991 – VStG:

Euro as a contribution to the costs of the criminal proceedings, which is 10% of the fine,

but at least 10 Euro;

Euro as compensation for cash expenses for

The total amount to be paid (fine/costs/cash expenses) therefore amounts to

Euro

****Payment Deadline:****

If no appeal is filed, this criminal finding is immediately enforceable. In this case, the total amount is to be paid within two weeks after the legal force takes effect to the account [Note from the editor: here abbreviated]. Please indicate the business number and the date of completion as the purpose of use. If payment is not made within this period, the total amount may be collected. In this case, a flat-rate cost contribution of five Euro is to be paid. If payment is still not made, the outstanding amount will be enforced.

****Reasoning:****

1.

The following decision-relevant facts are established based on the conducted evidentiary proceedings:

1.1. Regarding the information provided on the website of the Accused, the deletion request of the affected person, and the complaint procedure for case number D124.3076
1.100

12.100

1.1.1. The accused organizes a ****football league. The website of the accused publicly displays the following information about individuals who have participated in at least one game in the league organized by the accused:

- Player data
- Name with photo
- Year of birth
- Status (eligible to play or not)
- Team
- With the club since
- Nationality
- Jersey number
- Information and statistics
- Goals per game
- On Field Percentage
- Goals by half
- Win/Draw/Loss
- Score Percentage
- On Fire Rate
- Club loyalty
- Current season
- Games
- Goals
- Yellow cards
- Yellow/Red cards
- Red cards
- All-time statistics
- Games
- Goals
- Yellow cards
- Yellow/Red cards
- Red cards

In addition, all games in which a person has participated are listed in the player profile.

Evidence assessment for 1.1.1: These findings are based on a query of the website of the accused (last queried on December 19, 2023, for example see:

https://www.n***.com/index.php?action=showPlayer&id;=2*9*3, screenshots of this in the electronically maintained case file).

1.1.2. Mr. Roberto B*** (hereinafter: the affected party) participated in games in the league organized by the accused. He played his last game on October 6, 2019.

The affected party submitted a request for the deletion of his personal data to the accused via email on September 23, 2020, in which he asked to be removed from the systems of the accused.

The accused stated in messages to the affected party dated September 23, 2020, September 24, 2020, and September 26, 2020, that it could not comply with his request. In summary, deletion for statistical reasons was not possible.

The affected party subsequently filed a complaint with the data protection authority on October 1, 2020. The complaint procedure was assigned the case number D124.3076.

The data protection authority granted the affected party's complaint with a decision dated May 10, 2021 (GZ: D124.3076, 2021-0.096.835) and stated in point 1 of the ruling that the accused violated the affected party's right to deletion by rejecting his deletion request of September 23, 2020.

With point 2 of the decision, the following instruction was issued to the accused (note: referred to as the respondent in the complaint procedure) (formatting not reproduced 1:1):

1. The R e s p o n d e n t is instructed to, within three weeks regarding the data of the complainant publicly accessible on the respondent's website (www.n***.com) under ID: *4*6

a. cease the D I S C L O S U R E by transmitting and

b. delete this data or store it in a n o n - p u b l i c l y accessible area.

This decision subsequently became legally binding.

Evidence assessment for 1.1.2: These findings are derived from the case file components of the complaint procedure D124.3076.

1.1.3. At the time of the decision, the player profile of the affected party still displays his name, as well as all game statistics.

Instead of the photo, a symbolic image with the inscription "NOT PUBLICLY ACCESSIBLE" is shown in the player profile. The information for Team appears as "Clubless." The information for Year of birth, Status, With the club since, Nationality, and Jersey number no longer appears.

The accused also did not fully comply with deletion requests from other affected individuals, and their names and all game statistics are still visible on the website of the accused.

The data protection authority instructed the accused in several decisions to delete data of affected individuals from their website. The accused did not comply with the instructions of the data protection authority.

The Federal Administrative Court also confirmed with a final ruling dated April 12, 2023, a decision by the Data Protection Authority, stating that data of an affected person must be deleted from the defendant's website. The defendant also ignored this ruling.

Evidence assessment for 1.1.3: The finding that the aforementioned data of the affected person is still publicly accessible results from a call to the URL https://www.n***.com/?action=showPlayer&id;=*4*6 (last queried by the Data Protection Authority on December 19, 2023, screenshot in the file). That the defendant has also not fully complied with requests for the deletion of other persons and that the Data Protection Authority has ordered the deletion in several decisions is evident from several complaint proceedings concluded by the Data Protection Authority (e.g., the complaint proceedings D124.1086, D124.3657, D124.1324/23). The finding that the Federal Administrative Court has confirmed a decision by the Data Protection Authority is derived from the corresponding ruling dated April 12, 2023; GZ: W252 2246403-1/10E. That the defendant has ignored this ruling is evident from a query of the player profile in question in that proceeding (see: https://www.n***.com/?action=showPlayer&id;=5*4*, last queried on December 29, 2023, screenshot in the file).

1.2. Regarding the course of the present administrative fine procedure

1.2.1. By letter dated May 2, 2022, the Data Protection Authority initiated the present administrative fine procedure and requested the defendant to provide justification and to disclose their financial circumstances.

Despite a telephone announcement on June 13, 2022, the defendant did not submit a written justification to the Data Protection Authority and did not comment on their financial circumstances.

1.2.2. By decision dated April 27, 2023, the Data Protection Authority suspended the present

administrative fine procedure until a final decision by the Court of Justice of the European Union in case C-807/21. This suspension decision became final due to the lack of an appeal.

By decision dated December 5, 2023, the Data Protection Authority lifted the suspension decision of April 27, 2023, ex officio and resumed the administrative fine procedure – taking into account the judgment of the CJEU dated December 5, 2023, in case C-807/21.

Evidence assessment for 1.2.1. and 1.2.2.: The findings are based on the content of the present administrative fine act. A record dated June 13, 2022, documented the course of the phone call with the then chairman of the defendant, in which he announced that he would submit a justification.

2.

Legally, it follows:

2.1. On the jurisdiction of the Data Protection Authority and the scope of application of the GDPR

According to Art. 83 para. 4 lit. a, fines of up to 10,000,000 EUR or, in the case of a company, up to 2% of its total worldwide annual turnover of the previous financial year may be imposed if the obligations of the controllers and processors under Articles 8, 11, 25 to 39, 42, and 43 are violated.

Art. 83 para. 5 lit. b GDPR stipulates that in the case of violations of the provisions of Art. 12 to 22 GDPR, fines of up to 20,000,000 EUR or, in the case of a company, up to 4% of its total worldwide annual turnover of the previous financial year may be imposed, depending on which amount is higher. According to Art. 83 para. 6 GDPR, in the event of non-compliance with an instruction from the supervisory authority under Article 58 paragraph 2, fines of up to 20,000,000 EUR or, in the case of a company, up to 4% of its total worldwide annual turnover of the previous financial year may be imposed, depending on which amount is higher.

According to § 22 para. 5 DSG, the jurisdiction for imposing fines against natural and legal persons for Austria as the national supervisory authority lies with the Data Protection Authority.

The Data Protection Authority is therefore competent in the present case.

2.2. On the processing of personal data and the responsibility of the defendant

According to Art. 2 para. 1 GDPR, the regulation applies to the wholly or partially automated processing of personal data as well as to the non-automated processing of personal data that are stored or are intended to be stored in a filing system.

There is no doubt regarding the existence of processing of personal data within the meaning of Art. 4 no. 1 and 2 GDPR, and this has not been disputed by the defendant.

The defendant undoubtedly processes personal data through the publication of the information mentioned in 1.1.1.

The role of the defendant as a controller according to Art. 4 no. 7 GDPR has also not been disputed at any time, and there were no indications in the proceedings for a contrary assumption. As a controller, the defendant is subject to the relevant obligations of the GDPR.

2.3. On the violation according to point I.

According to Art. 25 para. 1 GDPR, the controller shall, taking into account the state of the art, the costs of implementation, and the nature, scope, circumstances, and purposes of the processing as well as the varying likelihood and severity of the risks to the rights and freedoms of natural persons, implement appropriate technical and organizational measures – such as pseudonymization – designed to effectively ensure the principles of data protection, such as data minimization.

to implement and incorporate the necessary guarantees into the processing to comply with the requirements of the GDPR and to protect the rights of the data subjects. Recital 78 of the GDPR specifies what suitable technical and organizational measures may be.

It provides, among other things, the following regulations: In order to demonstrate compliance with this regulation, the controller should establish internal strategies and take measures that particularly meet the principles of data protection by design and data protection by default. Such measures could include, among other things, minimizing the processing of personal data, pseudonymizing personal data as soon as possible, ensuring transparency regarding the functions and processing of personal data, enabling the data subject to monitor the processing of personal data, and empowering the controller to create and improve security features.

The European Data Protection Board (EDPB) has emphasized in its guidelines on Article 25 of the GDPR that both the appropriate measures and the necessary guarantees should serve the same purpose, namely to protect the rights of the data subjects and to ensure that the protection of their personal data is integrated into the processing (cf. Guidelines 4/2019 on Article 25, para. 7).

Controllers must implement the principles to ensure data protection by design and by default. These principles include transparency, lawfulness, processing in good faith, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, as well as accountability.

It is important to highlight the principle of data minimization according to Article 5(1)(c) of the GDPR for the present case. Accordingly, personal data must be adequate, relevant, and limited to what is necessary for the purposes of processing.

The EDPB provides in the aforementioned guidelines several examples of key aspects of design and default settings concerning data minimization.

If it is not necessary for the processing that the final data set relates to an identified or identifiable individual (as in statistics), but this is the case during the initial processing, the controller must delete or anonymize the personal data as soon as identification is no longer necessary (cf. the already mentioned guidelines of the EDPB, para. 75 and 76).

Aspects of accountability are also found in the principle of "data protection by design" enshrined in Article 25(1) of the GDPR, according to which the means of processing, i.e., products, services, and applications, must be determined at the time of establishing the means for the processing.

****Processing as well as at the time of the actual processing must be chosen in such a way that the requirements of the GDPR can be met (cf. Baumgartner in Ehmann/Selmayr (eds.), DS-GVO2 [2018] Art. 25 para. 2; see also Hötzendorfer in Gantschacher/Jelinek/Schmidl/Spanberger (eds.), Commentary on the General Data Protection Regulation [2017] Art. 25 Note 3).**

A prerequisite for the processing of personal data in a responsible manner is that the controller possesses both the knowledge for the implementation of data protection and the necessary skills for this purpose. This means that the controller is aware of the data protection obligations arising from the GDPR and that they can comply with these obligations (cf. the aforementioned guidelines of the EDPB, para. 88).

The defendant should ensure—especially after a legitimate request for deletion—that the data published on their website no longer allows for any conclusions to be drawn about the affected person. This could be achieved, as explicitly mentioned by the EDPB in its guidelines, through anonymization (cf. the mentioned guidelines of the EDPB, para. 54; see also the decision of the DSB from 05.12.2018, DSB-D123.270/0009-DSB/2018 regarding anonymization as a means of deletion).

The Federal Administrative Court has also stated that the defendant is obliged under Art. 25 GDPR to take the principle of data protection into account through technical design. Accordingly, the argument that the data of affected individuals is needed for new registrations, transfers, and to verify multiple registrations in case of name similarity is irrelevant when affected individuals have already left the association of the defendant or have not been active players for many years (cf. the ruling of the BVwG from 12.04.2023, GZ: W252 2246403-1/10E).

As a result, the defendant has violated Art. 25 GDPR during the relevant period by not implementing appropriate technical and organizational measures so that in the event of a necessary deletion from the public database of the defendant, no conclusions can be drawn about affected individuals.

Thus, the defendant has fulfilled the objective elements of Art. 25 para. 1 GDPR during the relevant period.

****2.4. Regarding the violation according to item II.**

According to Art. 17 para. 1 GDPR, an affected person has the right to request the immediate deletion of their personal data from the controller, and furthermore, the controller is obliged to delete personal data immediately if one of the reasons listed in Art. 17 para. 1 lit. a – lit. f GDPR applies.

The affected individual stated in the complaint procedure regarding D124.3076 that they wish for the deletion of their data, which is processed publicly and could be found by search engines, as they no longer play football and therefore do not intend to participate again as a player in the football league organized by the defendant. The processing of their data is therefore no longer necessary.

****As the Data Protection Authority has definitively established in its decision dated May 10, 2023, the accused has violated the affected party's right to erasure by rejecting the affected party's erasure request dated September 23, 2020.****

The personal data of the affected party is no longer necessary for the purposes for which it was collected or processed in any other way, in accordance with Art. 17 para. 1 lit. a GDPR.

Furthermore, the personal data of the affected party is being processed unlawfully in accordance with Art. 17 para. 1 lit. d of the same regulation:

The accused has failed to name a specific legal basis in accordance with Art. 6 para. 1 GDPR for the data processing, despite requests from the Data Protection Authority in the complaint procedure regarding D124.3076 as well as in the present administrative penalty procedure.

It should be noted that any prior consent given by the affected party in accordance with Art. 7 para. 3 GDPR was revoked with the erasure request dated September 23, 2020. With the effective revocation of the affected party's consent, any potential legal basis according to Art. 6 para. 1 lit. a GDPR (lawfulness of processing based on the consent of the data subject) is also eliminated.

If the accused relies on a legitimate interest in accordance with Art. 6 para. 1 lit. f GDPR, it should be stated that the weighting of the original interests has since shifted, as the affected party has been out of the accused's football league for years. He played his last match on October 6, 2019. There is no longer any reason for which the affected party's data would still be needed for the football league organized by the accused. The interest of the public interested in sports competitions in data of a football player no longer participating in competitive matches is also to be assessed as low. Thus, the legitimate interest of the affected party prevails in this case.

The Data Protection Authority does not overlook that exceptions to Art. 17 para. 3 GDPR are regulated in Art. 17, however, the accused did not present any such exceptions, and they did not arise from the course of the proceedings.

From the perspective of the Data Protection Authority, the only applicable exception for processing that the accused could rely on is the archival purpose in the public interest according to Art. 17 para. 3 lit. d in conjunction with Art. 89 GDPR.

Since anonymizing the affected party's data does not make the match results impossible or seriously impair them, the exception is not applicable to the present case (regarding anonymization as a means of erasure, see again the decision of the DSB dated December 5, 2018, DSB-D123.270/0009-DSB/2018).

In particular, considering the factors of appropriateness, significance, and purpose orientation, retaining data in a form that allows the identification of the affected party appears unnecessary in this specific case (cf. Art. 5 para. 1 lit. c GDPR ("data minimization")). The principle of storage limitation (Art. 5 para. 1 lit. e GDPR) also supports this assessment.

The Data Protection Authority further notes that the Federal Administrative Court has reached the same conclusion in a similarly situated case (cf. BVwG W252 2246403-1/10E dated April 12, 2023). As can be inferred from the findings, the accused is still processing data of the affected party on their website and has not fully complied with the affected party's erasure request to date – despite the definitive decision of the Data Protection Authority.

Therefore, the accused violated the affected party's right to erasure in the relevant time period in accordance with Art. 17 GDPR, and the objective factual basis for this is fulfilled.

****2.5. Regarding the violation according to point III.****

The Data Protection Authority has the authority under Art. 58 para. 2 lit. c GDPR to instruct the controller or the processor to comply with the requests of the data subject to exercise their rights under this regulation.

In this case, the accused has only partially complied with the instruction of the supervisory authority.

Although the affected party's player photo and the information "Year of Birth," "Status," "Nationality," "In the Club Since," and "Jersey Number" were deleted at an unspecified time, the name and all other information listed under point 1.1.1 about the affected party remain publicly accessible on the accused's website.

In light of the established facts, the accused, as the controller in accordance with Art. 4 no. 7 GDPR, is responsible for the objective factual side of the administrative offense under Art. 58 para. 2 lit. c in conjunction with Art. 83 para. 6 GDPR, as they did not comply with the Data Protection Authority's instruction to delete the affected party's data or to store it in a non-publicly accessible area.

****2.6. Regarding the liability of the accused as a legal entity****

The conditions for imposing fines on both natural persons and legal entities are regulated in Art. 83 GDPR. However, the national legislator has further defined "general conditions for the imposition of fines" in § 30 para. 1 and 2 DSG.

According to § 30 para. 1 DSG, the Data Protection Authority can impose fines on a legal entity if violations of the provisions of the GDPR were committed by persons who acted either alone or as part of an organ of the legal entity and held a managerial position within the legal entity due to (1) the authority to represent the legal entity.

legal entity (2) the authority to make decisions on behalf of the legal entity, or
(3) a supervisory authority within the legal entity.

Legal entities can be held liable for violations of the provisions of the GDPR pursuant to § 30 para. 2 DSG even in cases where a lack of supervision or control by a person named in § 30 para. 1 DSG has enabled the commission of these violations by a person acting on behalf of the legal entity, provided that the act does not constitute a criminal offense falling under the jurisdiction of the courts.

The Administrative Court has, in its ruling of 12.05.2020 in Ro 2019/04/0229, for the first time addressed the applicability of the prerequisites for criminal liability under § 30 DSG in a procedure according to Art. 83 GDPR and stated in this context that a legal entity cannot act on its own and therefore its liability under § 30 DSG is a consequence of the factual, unlawful, and culpable behavior of a managing person in the sense of § 30 para. 1 DSG. Accordingly, for the effectiveness of the prosecution action directed against the legal entity, a precise description of the act of the natural person (managing person or so-called "attribution person") is necessary. The attribution of the act by the managing person to the legal entity must be included in the ruling, and the attribution person must also be named as an identified natural person (cf. VwGH 12.05.2020, Ro 2019/04/0229, with references). In other words: the data protection authority must name in the ruling of the penalty decision that natural person whose violation of the GDPR or the DSG is to be attributed to the responsible legal entity in the sense of Art. 4 No. 7 GDPR, in order to impose a fine under Art. 83 GDPR against the responsible legal entity.

By decision of 06.12.2021, the Berlin Court of Appeal requested the CJEU in the context of a preliminary ruling request under Art. 267 TFEU to interpret Art. 83 GDPR regarding the question of whether a company can be directly affected in the penalty proceedings due to a violation of Art. 83 GDPR and submitted the following questions in this context:

1.

Is Art. 83 para. 4 to 6 GDPR to be interpreted as incorporating the functional concept of the company assigned to Articles 101 and 102 TFEU and the principle of function bearers into domestic law, with the result that, under an extension of the underlying legal entity principle of § 30 OWiG, a penalty proceeding can be conducted directly against a company and the imposition of a fine does not require the determination of an administrative offense committed by a natural and identified person, possibly in full criminal liability?

2.

If the answer to question 1 is in the affirmative: Is Art. 83 para. 4 to 6 GDPR to be interpreted as requiring that the company must have culpably committed the violation mediated by an employee (cf. Art. 23 of Regulation (EC) No. 1/2003 of the Council)?

from December 16, 2002, for the implementation of the competition rules laid down in Articles 81 and 82 of the Treaty), or is a mere objective breach of duty attributable to the company sufficient for a fine

("strict liability")? The preliminary ruling request from the Berlin Court of Appeal raised the question of whether the provisions of § 30 para. 1 and 2 of the DSG could even be applied, as they may violate the directly applicable provisions of the GDPR, and whether the statements of the VwGH in its aforementioned ruling regarding the criminal liability of legal entities in proceedings under Article 83 of the GDPR can be upheld. Since the decision of the CJEU on these preliminary questions had a prejudicial effect on the present proceedings, the administrative fine proceedings were suspended.

The CJEU ultimately stated in its recent judgment of December 5, 2023, that the directly applicable provisions under Article 58 para. 2 lit. i and Article 83 para. 1 to 6 of the GDPR are to be interpreted as being in opposition to a national regulation that stipulates that a fine for a violation mentioned in Articles 83 para. 4 to 6 of the GDPR against a legal entity in its capacity as a controller can only be imposed if this violation has previously been attributed to an identified natural person.

In this context, the CJEU explained that legal entities are not only liable for violations committed by their representatives, directors, or managers but also for violations committed by any other person acting within the scope of the business activities and in the name of the legal entity. Furthermore, it must be possible to impose the fines provided for in Article 83 of the GDPR directly against legal entities (cf. CJEU of December 5, 2023, C-807/21, Deutsche Wohnen SE, para. 44).

The (substantive) prerequisites for the imposition of fines by supervisory authorities are precisely regulated in Articles 83 para. 1 to 6 of the GDPR, without any discretion for the Member States. The GDPR does not contain any provision stating that the imposition of a fine against a legal entity as a controller depends on prior determination that this violation was committed by an identified natural person. The GDPR merely grants Member States the possibility/authority to establish requirements for the procedure to be applied by supervisory authorities when imposing a fine; however, it does not allow for the establishment of substantive prerequisites that would supplement those in Articles 83 para. 1 and 6 of the GDPR (cf. CJEU C-807/21, para. 45 et seq.). Therefore, the prerequisites for the imposition of a fine under Article 83 of the GDPR by a supervisory authority arise exclusively from Union law.

The CJEU pointed out that a national regulation that establishes additional requirements for the imposition of fines under Article 83 of the GDPR violates Article 83 para. 1 of the GDPR, as it undermines the effectiveness and deterrent effect of fines, which im Rahmen der Strafzumessung anzuwenden.

4.

In Bezug auf die Höhe der Geldbuße ist festzustellen, dass die Datenschutzbehörde die Schwere der Verstöße, die Dauer der Rechtswidrigkeit, die Anzahl der betroffenen Personen sowie die Art der betroffenen Daten berücksichtigt hat. Die Behörde hat auch die Maßnahmen, die die Beschuldigte zur Minderung der Auswirkungen der Verstöße ergriffen hat, in ihre Überlegungen einbezogen.

5.

Die Datenschutzbehörde hat die Geldbuße unter Berücksichtigung aller relevanten Umstände festgelegt und dabei die Notwendigkeit einer abschreckenden Wirkung der Strafe betont. Es wurde festgestellt, dass die verhängte Geldbuße sowohl wirksam als auch verhältnismäßig ist, um die Einhaltung der DSGVO zu fördern und die Rechte der betroffenen Personen zu schützen.

6.

Zusammenfassend ist festzuhalten, dass die Datenschutzbehörde die gesetzlichen Vorgaben zur Verhängung der Geldbuße eingehalten hat und die Entscheidung auf einer umfassenden Prüfung der Umstände des Einzelfalls beruht. Die verhängte Geldbuße dient nicht nur der Bestrafung der Beschuldigten, sondern auch der Prävention zukünftiger Verstöße und der Sicherstellung eines hohen Schutzniveaus für personenbezogene Daten im Einklang mit den Zielen der DSGVO.

to be applied. The income and asset situation and any potential caregiving responsibilities of the accused are to be taken into account when determining fines (this naturally only applies to natural persons, but can be analogously applied to legal entities); this, however, only to the extent that the directly applicable provisions of the GDPR do not displace the provisions of the VStG and to the extent

that is mandated by Art. 83 para. 8 GDPR and Recital 148 with regard to the procedural guarantees to be ensured.

By virtue of Art. 83 para. 3 GDPR, it is ordered, in deviation from the cumulation principle established in § 22 para. 2 VStG, that in cases of the same or linked processing operations, through which there is intentional or negligent violation of multiple provisions of the GDPR, the total amount of the fine shall not exceed the amount for the most serious violation. Thus, within the scope of this provision, the absorption principle applies.

According to Art. 83 para. 5 lit. a and para. 6 GDPR, in the case of the violations mentioned therein, in accordance with para. 2, fines of up to EUR 20,000,000 or, in the case of a company, up to 4% of its total worldwide annual revenue from the previous financial year shall be imposed, depending on which amount is higher.

Furthermore, it should be noted in the sense of Art. 83 para. 1 GDPR that in the context of the determination of the "total amount of the fine" under the application of the absorption principle according to Art. 83 para. 3 GDPR, all violations committed against the GDPR must be taken into account. The wording "amount for the most serious violation" refers to the penalty range or the legally prescribed maximum amounts (see Art. 83 para. 4 to 6 GDPR). The EDPB stated that within the scope of Art. 83 para. 3 GDPR, the other violations committed cannot be de facto disregarded, but must be correspondingly taken into account in the determination of the penalty (cf. Fines Guidelines, Chapter 3 – para. 43). Otherwise, this would lead to a privileging of controllers and processors who have violated multiple provisions of the GDPR within the framework of an established factual situation.

Due to the lack of cooperation from the accused regarding the determination of their financial situation, the data protection authority had to make an estimate (cf. VwGH 11.05.1990, 89/18/0179; 22.04.1992, 92/03/0019; 23.02.1996, 95/02/0174). In light of the Fines Guidelines, the accused is classified in the lowest category ("Undertakings with a turnover up until € 2 Million") concerning their revenue and with regard to the imposition of an effective, deterrent, and proportionate fine during the estimation process. This classification duly takes into account the size of the company, particularly to ensure the proportionality of the fine.

The penalty range in the specific case extends according to Art. 83 para. 5 GDPR to an amount of EUR 20,000,000 (static penalty range). The dynamic penalty range (4% of annual revenue) does not apply.

In light of the established facts and taking into account the nature, severity, and duration of the infringement (Art. 83 para. 1 lit. a GDPR), the intentionality or negligence of the infringement (Art. 83 para. 2 lit. b GDPR), as well as the categories of personal data affected by the infringement (Art. 83 para. 2 lit. g GDPR), the Data Protection Authority determines the severity of the violation ("Seriousness of the infringement") to be at a medium level of seriousness ("medium level of seriousness").

In relation to the present case, the following aggravating factors were considered in the determination of the penalty (beyond the criteria already taken into account for the assessment of severity according to Art. 83 para. 1 lit. a, b, and g GDPR):

- The accused did not submit a written justification to the Data Protection Authority despite a prior telephone announcement, did not provide information regarding her financial situation, and thus cooperated with the Data Protection Authority to a very limited extent (cf. Art. 83 para. 1 lit. f GDPR).

In relation to the present case, the following mitigating factors were considered in the determination of the penalty:

- There are no relevant previous violations of the GDPR against the accused at the Data Protection Authority (cf. Art. 83 para. 2 lit. e GDPR).

According to the consistent case law of the Administrative Court (VwGH), considerations of special prevention and general prevention may also be included in the assessment of the penalty (cf. VwGH 15.5.1990, 89/02/0093, VwGH 22.4.1997, 96/04/0253, VwGH 29.1.1991, 89/04/0061).

The imposition of the specific monetary fine was necessary in terms of special prevention to deter the accused from committing further violations, to encourage her to implement data protection through privacy by design and default settings in accordance with Art. 25 GDPR, and to raise her awareness of her obligations regarding deletion requests and compliance with instructions from the Data Protection Authority. It is to be assumed that without the imposition of a monetary fine, the accused would continue the processing in question, as she has already disregarded a legally binding decision from the Federal Administrative Court.

Furthermore, the imposition of the monetary fine was also necessary in terms of general prevention to raise awareness among responsible parties regarding data processing in the context of comparable publicly accessible databases, as well as regarding the handling of deletion requests and performance orders from the Data Protection Authority.

The specific penalty imposed in the amount of EUR 11,000 appears to be appropriate in relation to the value of the act committed, measured against the available penalty range (here up to EUR 20,000,000), and is at the lower end of the available penalty range.